

W14D1 - Local Password Cracking

metasploitable - pentesting

Password Cracking

Danilo 'danix' Macrì - mia.mail@mio.sito

Scan started on 13/09/2025 - duration (days): 1

Contents

Sommario	1
Scope	1
Tecnologie utilizzate	1
Esecuzione	2
John the ripper	2
hashcat	3

Sommario

Oggi eseguiremo un tentativo di cracking delle password scoperte durante l'attività di SQL injection (SQLi) sulla nostra macchina Metasploitable2, avvenuta nell'esercizio precedente.

Questo è il contenuto del file estratto, contenente gli hash delle password del database:

```
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

Scope

- Il target dei nostri test è come sempre la macchina metasploitable
 - 192.168.50.101
 - http://metasploitable

Tecnologie utilizzate

Per i nostri test di oggi utilizzeremo i seguenti software:

- John the Ripper 1.9.0-jumbo
- hashcat v7.1.2

Esecuzione

John the ripper

```
john -incremental --format=raw-md5 --min-length=4 --max-length=12 dvwa_users.txt
```

Le opzioni utilizzate per john sono le seguenti:

--incremental la modalità più potente, verrà testata ogni combinazione di caratteri per risolvere la password

--format=raw-md5 specifica il formato del testo cifrato. Si può anche lasciare che john lo deduca autonomamente.

--min-length=4 la lunghezza minima che john deve considerare nel testare la password, è un parametro che si può omettere per lasciare che john testi da una lunghezza minima di un carattere in su.

--max-length=12 come il parametro precedente, anche questo opzionale, specifica la lunghezza massima della password da indovinare

```
(kali㉿kali)-[~]
$ cat dvwa_users.txt
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99

(kali㉿kali)-[~]
$ john -incremental --format=raw-md5 --min-length=4 --max-length=12 dvwa_users.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
abc123      (gordonb)
charley     (1337)
password    (admin)
letmein     (pablo)
4g 0:00:00:00 DONE (2025-10-13 09:36) 12.90g/s 8232Kp/s 8232Kc/s 9664KC/s letel23..letm360
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~]
$ john --show --format=Raw-MD5
Password files required, but none specified

(kali㉿kali)-[~]
$ john --show --format=Raw-MD5 dvwa_users.txt
admin:password
gordonb:abc123
1337:charley
pablo:letmein
smithy:password

5 password hashes cracked, 0 left
```

Come si vede dallo screenshot le password sono state craccate con successo e il comando:

```
john --show --format=Raw-MD5 dvwa_users.txt
```

ce ne darà la conferma visualizzando le password in chiaro.

hashcat

```
hashcat -m 0 dvwa_users.txt  
↪ /usr/share/wordlists/seclists/Passwords/Leaked-Databases/rockyou-70.txt --username --status
```

Abbiamo già visto in azione questo comando nell'esercizio precedente, rivediamolo nel dettaglio:

-m 0 il tipo di hash utilizzato, si può far riferimento alla [documentazione di hashcat](#) per la lista completa di hash supportati.

--username permette di ignorare gli username nel file di hash.

--status aggiorna la schermata con informazioni sul progresso della scansione.

```
(kali@kali)-[~]  
$ cat .local/share/hashcat/hashcat.potfile  
5f4dcc3b5aa765d61d8327deb882cf99:password  
e99a18c428cb38d5f260853678922e03:abc123  
0d107d09f5bbe40cade3de5c71e9e9b7:letmein  
8d3533d75ae2c3966d7e0d4fcc69216b:charley
```

Dopo pochissimo, il file hashcat.potfile conterrà le password craccate.

Si conclude così il nostro test di oggi.

Alla prossima.

